ANNEXE F

Plan d'Actions de Sécurité

Version : 1.0

Classification : Interne

Statut : Approuvée

Auteur : Consultant Cybersécurité

Approbateur : Direction Générale — Antoine Verger

Historique des versions

Version	Date	Auteur	Description
0.1	15/06/2026	Consultant cybersécurité	Création du document
0.9	20/06/2026	DSI	Relecture technique
1.0	30/06/2026	Direction Générale	Validation officielle

Diffusion

Destinataire	Diffusion
Direction Générale	Oui
DSI	Oui
Responsable RH	Oui
DPO	Oui
Équipe informatique	Oui
Managers	Oui
Collaborateurs	Version adaptée

Table des matières

1. Présentation du plan d'actions 3
2. Objectifs du plan d'actions 5
3. Références et exigences 6
4. Démarche de priorisation 8
5. Plan d’actions de sécurité 9
6. Architecture cible sécurisée 15

1. Présentation du plan d'actions

1.1 Objet

Le présent Plan d'Actions de Sécurité formalise les actions retenues par BioMarket afin de réduire les risques identifiés et d'améliorer le niveau de sécurité du système d'information dans le cadre de la mise en œuvre du SMSI.

Les actions proposées découlent notamment :

- de la Politique de Sécurité du Système d'Information (PSSI) ;
- de l'analyse des risques réalisée selon la méthode EBIOS Risk Manager ;
- des besoins métiers identifiés ;
- des exigences réglementaires applicables, notamment le RGPD ;
- des objectifs de certification ISO/IEC 27001.

Le document constitue un outil de pilotage permettant de prioriser, planifier et suivre les actions de sécurité jusqu'à leur mise en œuvre.

1.2 Finalité

Le plan d'actions poursuit les objectifs suivants :

- réduire les risques identifiés lors de l'analyse des risques ;
- renforcer la protection des données sensibles ;
- améliorer le contrôle des accès ;
- améliorer la détection et la gestion des incidents ;
- renforcer la résilience du système d'information ;
- maîtriser les risques liés aux prestataires ;
- réduire les risques liés aux erreurs humaines ;
- préparer BioMarket à la certification ISO/IEC 27001 ;
- assurer la conformité aux exigences réglementaires applicables.

1.3 Périmètre

Le plan d'actions couvre les principaux composants du périmètre du SMSI :

- infrastructures réseau ;
- serveurs ;
- Active Directory ;
- postes de travail ;
- applications métiers ;

- données clients ;
- données RH ;
- sauvegardes ;
- accès des collaborateurs ;
- accès des prestataires.

La plateforme e-commerce est prise en compte pour les aspects relevant du système d'information de BioMarket, de ses données et de ses échanges avec le prestataire.

L'infrastructure interne PaaS administrée par Iron4Software reste hors du périmètre opérationnel de BioMarket. En revanche, les accès du prestataire et les exigences de sécurité applicables aux échanges avec celui-ci sont intégrés au plan d'actions.

1.4 Principes de mise en œuvre

Les actions retenues doivent :

- être adaptées aux risques identifiés ;
- être techniquement réalisables dans l'environnement de BioMarket ;
- être proportionnées aux enjeux métiers ;
- limiter les impacts sur les utilisateurs et les activités ;
- respecter les exigences réglementaires applicables ;
- être compatibles avec les objectifs de certification ISO/IEC 27001 ;
- faire l'objet d'un suivi permettant de mesurer leur avancement et leur efficacité.

---

2. Objectifs du plan d'actions

2.1 Objectifs de sécurité

Les mesures proposées visent notamment à :

- renforcer le contrôle des accès aux ressources sensibles ;
- appliquer le principe du moindre privilège ;
- protéger les données par des mécanismes cryptographiques adaptés ;
- améliorer la détection des incidents ;
- limiter la propagation des attaques ;
- renforcer la disponibilité des systèmes critiques ;
- sécuriser les accès des prestataires ;
- renforcer la sensibilisation des collaborateurs.

2.2 Lien avec l'analyse des risques

Les actions sont directement liées aux principaux risques identifiés dans l'Annexe D :

Risque	**Principales actions de traitement**
Compromission d'un compte administrateur	MFA, comptes administrateurs dédiés, revue des habilitations, journalisation
Rançongiciel	EDR, segmentation réseau, sauvegardes, restauration et tests
Compromission d'un prestataire	MFA, limitation des privilèges, contrôle et journalisation des accès
Fuite de données personnelles	habilitations, classification, chiffrement, sensibilisation

---

3. Références et exigences

3.1 Documents de référence

Le présent plan d'actions s'appuie sur les documents élaborés dans le cadre du projet de mise en œuvre du SMSI de BioMarket :

- Annexe A - BioMarket – Etude du contexte;
- Annexe B – Plan Projet pour la Certification du SMSI ;
- Annexe C – Politique de Sécurité du Système d'Information (PSSI) ;
- Annexe D – Analyse des risques ;
- Annexe E – Plan de Continuité d'Activité (PCA) ;
- cartographie et architecture du système d'information de BioMarket.

Ces documents constituent les principales sources permettant d'identifier les mesures de sécurité à mettre en œuvre et d'assurer leur cohérence avec les objectifs du SMSI.

3.2 Référentiels et exigences applicables

Le plan d'actions prend notamment en compte :

- la norme ISO/IEC 27001:2022 ;
- le Règlement Général sur la Protection des Données (RGPD) ;
- les recommandations et bonnes pratiques de l'ANSSI ;
- les exigences de sécurité définies dans la PSSI de BioMarket.

Les actions sont définies de manière à contribuer à la réduction des risques identifiés et à la préparation de BioMarket à la certification ISO/IEC 27001.

3.3 Traçabilité avec la PSSI et l'analyse des risques

Les actions du présent plan sont issues des mesures de sécurité définies dans la PSSI et des traitements retenus à la suite de l'analyse des risques.

Source	**Éléments pris en compte**
PSSI	Contrôle des accès, gestion des habilitations, chiffrement, journalisation, sensibilisation, gestion des changements
Analyse des risques	Compromission des comptes administrateurs, ransomware, fuite de données personnelles, compromission d'un prestataire, erreur humaine
PCA	Sauvegarde, restauration, continuité des services, gestion de crise et tests
Exigences réglementaires	Protection des données personnelles, confidentialité, disponibilité et traçabilité

Cette traçabilité permet de démontrer que les actions proposées répondent aux risques identifiés et aux orientations définies par la PSSI. L'analyse de risques prévoit notamment le MFA, les comptes d'administration dédiés, la revue des habilitations, la segmentation réseau, l'EDR, le chiffrement et le contrôle des accès prestataires.

---

4. Démarche de priorisation

4.1 Critères de priorisation

Les actions de sécurité sont priorisées selon les critères suivants :

- niveau de risque identifié lors de l'analyse EBIOS Risk Manager ;
- impact sur les activités métiers ;
- impact sur la sécurité de l'information ;
- faisabilité technique et organisationnelle ;
- coût estimatif de mise en œuvre ;
- dépendances avec d'autres actions ou projets.

Cette approche permet de concentrer en priorité les ressources de BioMarket sur les mesures permettant de réduire les risques les plus importants.

4.2 Niveaux de priorité

Priorité	**Description**
P1 – Critique	Action prioritaire nécessitant une mise en œuvre à court terme afin de réduire un risque critique.
P2 – Haute	Action importante à réaliser à court terme afin de réduire un risque élevé ou de renforcer significativement le niveau de sécurité.
P3 – Moyenne	Action à planifier à moyen terme afin d'améliorer le niveau de sécurité ou la conformité.
P4 – Faible	Action d'amélioration pouvant être réalisée à plus long terme.

4.3 Évaluation de la faisabilité et des impacts

Avant leur mise en œuvre, les actions sont évaluées selon :

- leur faisabilité technique au regard de l'architecture existante ;
- leur faisabilité organisationnelle ;
- leur impact sur les utilisateurs ;
- leur impact sur les activités métiers ;
- leur coût de mise en œuvre ;
- les ressources nécessaires.

Cette évaluation permet de sélectionner des mesures proportionnées aux risques et adaptées aux capacités de BioMarket.

5. Plan d’actions de sécurité

5.1 Synthèse des actions

Le plan d’actions de sécurité traduit les mesures de traitement des risques identifiées dans l’analyse de risques et les orientations définies dans la PSSI en actions concrètes.

Les actions sont priorisées selon le niveau de risque traité, leur impact sur la sécurité du système d'information, leur faisabilité et leur coût. Leur mise en œuvre est suivie par la DSI et fait l'objet d'un pilotage régulier dans le cadre du SMSI.

N°	Action	Risque traité	Priorité	Responsable	Échéance	Coût estimé
A1	Généraliser l'authentification multifacteur (MFA)	Compromission des comptes	P1	DSI	3 mois	15 000 €
A2	Mettre en place une revue semestrielle des habilitations	Accès non autorisés	P1	DSI / RH	2 mois	15 000 €
A3	Renforcer la politique de mots de passe	Vol d'identifiants	P1	DSI	1 mois	10 000 €
A4	Chiffrer les postes portables avec BitLocker	Perte ou vol de matériel	P2	DSI	4 mois	15 000 €
A5	Chiffrer les sauvegardes	Perte de confidentialité	P2	DSI	3 mois	25 000 €
A6	Déployer une solution EDR	Malware / ransomware	P1	DSI	4 mois	30 000 €
A7	Centraliser les journaux de sécurité	Détection des incidents	P2	DSI	6 mois	30 000 €
A8	Sensibiliser les collaborateurs à la cybersécurité	Phishing / erreur humaine	P2	DSI / RH	Annuel	10 000 €
A9	Renforcer le contrôle des accès des prestataires	Compromission d'un tiers	P2	DSI	2 mois	20 000 €
A10	Formaliser la gestion des changements	Erreurs de configuration	P3	DSI	3 mois	5 000 €
A11	Renforcer la segmentation réseau et isoler les serveurs critiques	Propagation d'un ransomware	P1	DSI	6 mois	20 000 €

Les actions A1 à A10 reprennent les principales mesures de sécurité identifiées dans le cadre du projet. La mesure A11 complète ce plan afin d'intégrer le renforcement de la segmentation réseau identifié dans l'analyse des risques et nécessaire à la définition de l'architecture cible sécurisée

Le coût estimatif global du plan d'actions de sécurité s'élève à 195 000 € HT. Ce montant constitue une estimation prévisionnelle et pourra être ajusté lors de la mise en œuvre en fonction des solutions retenues et des conditions de déploiement.

5.2 Actions sur le contrôle des accès

Le contrôle des accès constitue un axe prioritaire du plan d'actions, notamment en raison du risque de compromission des comptes administrateurs et du risque d'accès non autorisé aux données.

Action	Justification	Bénéfice attendu
Authentification multifacteur (MFA)	Réduire les risques liés au vol d'identifiants	Renforcement de la sécurité des comptes sensibles
Revue périodique des habilitations	Appliquer le principe du moindre privilège	Limitation des accès non autorisés
Comptes administrateurs dédiés	Séparer les usages bureautiques et administratifs	Réduction du risque de compromission des comptes privilégiés
Politique de mots de passe renforcée	Améliorer la robustesse de l'authentification	Réduction des attaques liées aux identifiants
Contrôle des accès prestataires	Maîtriser les accès accordés aux tiers	Réduction du risque de compromission d'un prestataire
Journalisation des connexions	Détecter les accès anormaux	Amélioration de la traçabilité

Ces mesures reprennent directement les traitements définis dans l'analyse des risques pour les comptes administrateurs, les données personnelles et les accès prestataires.

5.3 Actions sur les solutions cryptographiques

Afin de renforcer la confidentialité et l'intégrité des informations, BioMarket prévoit plusieurs mesures de chiffrement.

Action	Périmètre	Objectif
Chiffrement des postes portables avec BitLocker	Postes portables	Protéger les données en cas de perte ou de vol du matériel
Chiffrement des sauvegardes	Sauvegardes	Protéger la confidentialité des données sauvegardées

Action	Périmètre	Objectif
Chiffrement des données sensibles	Données sensibles	Réduire le risque de divulgation des informations

Ces mesures répondent notamment au risque de fuite de données personnelles. L'analyse de risques retient explicitement le chiffrement des informations sensibles parmi les mesures de traitement.

5.4 Actions de détection et de supervision

Les actions de détection et de supervision visent à améliorer la capacité de BioMarket à identifier rapidement les comportements anormaux, les tentatives d'intrusion et les incidents de sécurité.

Action	Justification	Bénéfice attendu
Déploiement d'une solution EDR	Détecter les comportements malveillants sur les postes et serveurs	Amélioration de la détection et de la réponse aux incidents
Centralisation des journaux de sécurité	Regrouper les événements issus des équipements et systèmes critiques	Amélioration de la supervision et de la traçabilité
Surveillance des accès privilégiés	Identifier les connexions et activités anormales sur les comptes sensibles	Réduction du risque de compromission des comptes administrateurs
Conservation des journaux	Disposer d'éléments permettant l'analyse des incidents	Facilitation des investigations et du RETEX

A6 – Déploiement d'une solution EDR

La mise en place d'une solution EDR sur les postes et serveurs doit permettre de détecter les comportements malveillants et de contribuer à limiter les conséquences d'une attaque, notamment en cas de malware ou de rançongiciel.

Responsable : DSI
Priorité : P1 – Critique
Échéance : 4 mois
Coût estimatif : 30 000 € HT

A7 – Centralisation des journaux de sécurité

Les journaux de sécurité des principaux systèmes et équipements doivent être centralisés afin d'améliorer la détection des événements anormaux, leur analyse et la traçabilité des actions réalisées sur le système d'information.

Responsable : DSI
Priorité : P2 – Haute
Échéance : 6 mois
Coût estimatif : 30 000 € HT

Ces deux actions correspondent aux mesures déjà présentes dans le plan d'actions initial et sont cohérentes avec l'objectif d'amélioration de la détection et de la supervision de la sécurité.

5.5 Actions de continuité et de résilience

Les actions de continuité et de résilience visent à réduire l'impact d'un incident majeur sur les activités critiques de BioMarket et à permettre une reprise dans les délais définis par le PCA.

Action	**Justification**	**Bénéfice attendu**
Chiffrement des sauvegardes	Protéger les données sauvegardées	Renforcement de la confidentialité
Renforcement de la segmentation réseau	Limiter la propagation d'une attaque	Réduction de l'impact d'un ransomware
Isolation des serveurs critiques	Réduire les possibilités de propagation latérale	Protection des ressources essentielles
Tests de restauration	Vérifier la capacité effective de récupération	Amélioration de la résilience
Tests et exercices PCA/PRA	Vérifier l'efficacité du dispositif	Amélioration de la capacité de reprise

La segmentation réseau et l'isolation des serveurs critiques sont intégrées au plan d'actions afin d'assurer la cohérence avec l'architecture cible sécurisée demandée dans le sujet et avec les mesures de traitement du risque de rançongiciel identifiées précédemment.

Responsable principal : DSI
Priorité : P1 – Critique pour la segmentation et l'isolation
Échéance : 6 mois
Coût : 20 000 € HT.

Pour le reste, les modalités de sauvegarde, de restauration et de tests sont détaillées dans **l'Annexe E – PCA**.

5.6 Actions liées aux utilisateurs et aux prestataires

Les actions liées aux utilisateurs et aux prestataires visent à réduire les risques associés aux comportements humains, aux erreurs de manipulation ainsi qu'aux accès accordés aux intervenants externes.

A8 – Sensibiliser les collaborateurs à la cybersécurité

Un programme de sensibilisation doit être déployé afin de renforcer les bonnes pratiques des collaborateurs, notamment concernant le phishing, la gestion des mots de passe, la protection des informations sensibles et le signalement des incidents.

Responsable : DSI / RH
Priorité : P2 – Haute
Échéance : Annuelle
Coût estimatif : 10 000 € HT

Cette action est cohérente avec le programme annuel de sensibilisation prévu dans l'Annexe C6.

A9 – Renforcer le contrôle des accès des prestataires

Les accès accordés aux prestataires doivent être limités aux ressources nécessaires à leurs missions et faire l'objet d'un contrôle adapté.

Les mesures comprennent notamment :

- identification des comptes et accès prestataires ;
- limitation des privilèges au strict nécessaire ;
- utilisation du MFA lorsque disponible ;
- revue périodique des accès ;
- suppression des accès devenus inutiles ;
- journalisation des connexions ;
- définition des exigences de sécurité applicables aux prestataires.

Responsable : DSI
Priorité : P2 – Haute
Échéance : 2 mois
Coût estimatif : 20 000 € HT

Cette action répond notamment au risque de compromission d'un prestataire identifié dans l'analyse de risques.

5.7 Gestion des changements

A10 – Formaliser la gestion des changements

Toute modification significative du système d'information doit être identifiée, évaluée, validée et documentée avant sa mise en œuvre.

La procédure doit notamment permettre de :

- décrire le changement envisagé ;
- identifier son impact potentiel sur la sécurité et les activités ;
- évaluer les risques associés ;
- définir les mesures de maîtrise nécessaires ;
- obtenir la validation appropriée ;
- planifier et réaliser le changement ;
- vérifier son bon fonctionnement après mise en œuvre ;
- conserver une trace du changement réalisé.

Responsable : DSI
Priorité : P3 – Moyenne

Échéance : 3 mois
Coût estimatif : 5 000 € HT

Cette action est cohérente avec la **Procédure de gestion des changements – Annexe C3** et vise notamment à réduire les risques liés aux erreurs de configuration ou aux modifications non maîtrisées.

5.8 Synthèse de la priorisation

Les actions **P1** sont traitées en priorité car elles répondent aux risques critiques identifiés. Les actions **P2** contribuent à renforcer significativement le niveau de sécurité et sont planifiées à court terme. Les actions **P3** sont mises en œuvre progressivement selon les ressources disponibles et les priorités du SMSI.

Le suivi de l'avancement, des responsables, des échéances et des éventuels écarts est réalisé dans le tableau de bord du plan d'actions.

6. Architecture cible sécurisée

6.1 Principes de l'architecture cible

L’architecture cible vise à renforcer la sécurité du système d'information de BioMarket tout en maintenant les besoins de disponibilité et d'accès aux services métiers.

Elle repose sur les principes suivants :

- Renforcement de la segmentation réseau par VLAN, avec création d'une zone dédiée aux serveurs critiques ;
- isolation des serveurs critiques dans un VLAN/segment dédié, séparé des réseaux utilisateurs ;
- filtrage des flux inter-zones par le pare-feu UTM, en n'autorisant que les communications nécessaires ;
- mise en place d'une DMZ pour les services nécessitant une exposition vers des réseaux externes ;
- sécurisation des accès distants au moyen d'un VPN ;
- généralisation de l'authentification multifacteur (MFA) ;
- centralisation des journaux de sécurité.

Cette architecture constitue la cible de sécurisation du système d'information et traduit techniquement les principales actions définies dans le présent plan.

6.2 Mesures de sécurisation

Les principales évolutions de l’architecture cible sont les suivantes :

Mesure	**Mise en œuvre**	**Objectif**
Segmentation réseau	Séparation des usages au moyen de VLAN dédiés : utilisateurs, serveurs, infrastructure, management, serveurs critiques et sauvegardes	Limiter les communications non nécessaires et réduire les mouvements latéraux
Isolation des serveurs critiques	Création d’un VLAN dédié aux serveurs critiques (VLAN 70) et filtrage des flux inter-VLAN par le pare-feu UTM	Protéger les ressources critiques et limiter la propagation d’une compromission
Segmentation des sauvegardes	Création d’un VLAN dédié aux sauvegardes (VLAN 80) et limitation des flux aux seuls besoins de sauvegarde et de restauration	Renforcer la résilience face aux incidents, notamment aux rançongiciels
DMZ	Mise en place d’une zone dédiée aux services exposés, notamment l’application/API e-commerce	Séparer les services exposés du réseau interne

Mesure	Mise en œuvre	Objectif
Pare-feu UTM	Mise en place de règles de filtrage entre les différentes zones selon le principe du moindre privilège	Contrôler les flux et limiter les accès non autorisés
VPN	Utilisation du VPN SSL pour les accès distants des utilisateurs nomades et les accès sécurisés des prestataires	Protéger les connexions externes au SI
MFA	Généralisation de l'authentification multifacteur pour les accès distants et privilégiés	Réduire le risque de compromission des comptes
Centralisation des journaux	Déploiement d'un SIEM pour centraliser les journaux du pare-feu, des serveurs, de l'Active Directory, des équipements réseau et des accès distants	Améliorer la détection, la supervision et la traçabilité des incidents

6.3 Flux et accès sécurisés

Les flux entre les différents environnements du système d'information sont contrôlés selon leur origine, leur destination et le niveau de sensibilité des ressources concernées.

Les accès distants des utilisateurs nomades sont réalisés au travers du VPN SSL de BioMarket et soumis à une authentification multifacteur. Les accès aux ressources sensibles sont contrôlés conformément aux mécanismes d'authentification et d'habilitation définis par la PSSI.

Les accès des prestataires, notamment Iron4Software, sont limités aux ressources nécessaires à leurs interventions. Ils sont réalisés au moyen d'un accès sécurisé et soumis au MFA, avec journalisation des connexions.

Les services nécessitant une exposition vers des réseaux externes sont placés dans une DMZ. Les flux entrants sont limités aux ports et services nécessaires.

Les flux entre les réseaux utilisateurs, les serveurs internes et les serveurs critiques sont filtrés par le pare-feu UTM. Les accès directs des réseaux utilisateurs vers le VLAN dédié aux serveurs critiques sont interdits, sauf flux explicitement autorisés.

Les sauvegardes sont isolées dans un VLAN dédié et protégées contre les accès non autorisés. Les communications avec les services Cloud sont réalisées au moyen de connexions sécurisées.

Les journaux des équipements réseau, des serveurs, de l'Active Directory, du VPN et des accès prestataires sont centralisés dans le SIEM afin d'améliorer la détection et la traçabilité des événements de sécurité.

6.4 Principaux flux autorisés

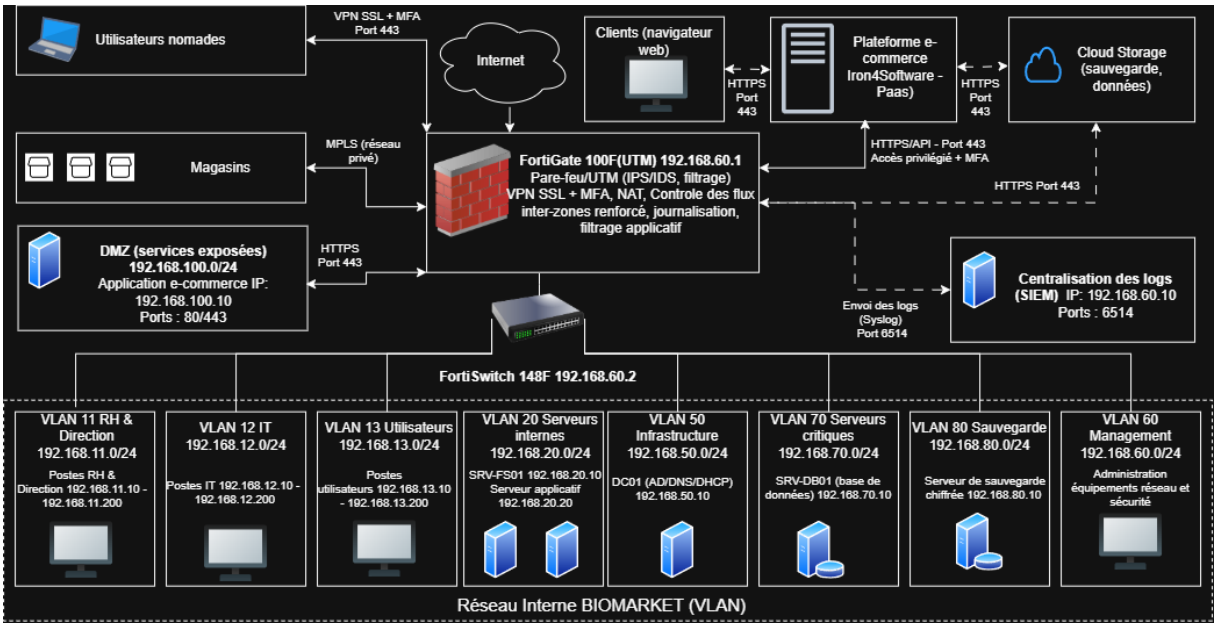
Les principaux flux autorisés dans l'architecture cible sont définis selon le principe du moindre privilège. Seuls les échanges nécessaires au fonctionnement des services, à l'administration et à la continuité d'activité sont autorisés.

Source	Destination	Flux	Mesure de sécurité
Utilisateurs nomades	FortiGate	VPN SSL / 443	MFA
Prestataire Iron4Software	Ressources BioMarket autorisées	VPN / accès sécurisé	MFA + journalisation
Clients Internet	Application e-commerce en DMZ	HTTPS / 443	Filtrage UTM
Plateforme e-commerce	API / ressources BioMarket	HTTPS / 443	Filtrage des flux
Salariés	Cloud Storage	HTTPS / 443	Contrôle par le pare-feu
Serveurs internes	Serveur de sauvegarde	Flux de sauvegarde	Flux limités
Serveur de sauvegarde	Cloud Storage	HTTPS / 443	Communication sécurisée
VLAN utilisateurs	VLAN 70 – Serveurs critiques	Aucun accès direct	Interdit par défaut
Équipements et serveurs	SIEM	Envoi des journaux	Centralisation et supervision

Les règles de filtrage sont appliquées au niveau du pare-feu UTM et doivent être documentées et maintenues en fonction des besoins métiers et des évolutions du système d'information.

6.5 Architecture cible – Cartographie

L'architecture cible présentée ci-dessous traduit les mesures de sécurisation définies dans le cadre du SMSI. Elle vise notamment à renforcer la segmentation du système d'information, à isoler les serveurs critiques et les sauvegardes, à sécuriser les accès distants et privilégiés et à améliorer la supervision des événements de sécurité.



Cette architecture constitue une cible de sécurisation. Sa mise en œuvre devra être accompagnée de la définition des règles de filtrage, de la configuration des mécanismes d'authentification et de la mise en place de la centralisation des journaux conformément au plan d'actions de sécurité.

6.6 Justification de l'architecture cible

L'architecture cible répond aux principaux risques identifiés dans l'analyse de risques et aux mesures définies dans le plan d'actions de sécurité.

La segmentation en VLAN permet de limiter les communications entre les différents environnements du système d'information et de réduire les possibilités de mouvements latéraux en cas de compromission. L'isolation des serveurs critiques et des sauvegardes renforce la protection des ressources essentielles et la résilience face aux rançongiciels.

La mise en place d'une DMZ permet de séparer les services exposés vers l'extérieur du réseau interne. Le pare-feu UTM assure le contrôle des flux entre les différentes zones selon le principe du moindre privilège.

Le VPN et l'authentification multifacteur renforcent la sécurité des accès distants et privilégiés, notamment pour les utilisateurs nomades et les prestataires. Enfin, la centralisation des journaux dans un SIEM améliore la supervision, la détection et la traçabilité des événements de sécurité.

L'architecture cible constitue ainsi une évolution progressive de l'architecture existante et fournit un cadre technique cohérent avec les objectifs de sécurité définis par le SMSI.

7. Note de cadrage du projet

La présente note de cadrage définit le cadre de mise en œuvre du plan d'actions de sécurité de BioMarket. Elle précise les objectifs du projet, la démarche retenue ainsi que les ressources nécessaires à sa réalisation.

7.1 Objectifs du projet

Le projet vise à renforcer le niveau de sécurité du système d'information de BioMarket en mettant en œuvre les actions prioritaires identifiées à partir de la PSSI et de l'analyse des risques.

Les principaux objectifs sont :

- réduire les risques liés aux comptes privilégiés et aux accès distants ;
- renforcer la protection des données et des ressources critiques ;
- améliorer la détection et la traçabilité des événements de sécurité ;
- renforcer la résilience du SI face aux incidents, notamment aux rançongiciels ;
- mettre en cohérence les mesures de sécurité avec les exigences du SMSI et les exigences réglementaires applicables.

7.2 Démarche de sécurité

La démarche repose sur une approche progressive fondée sur les risques. Les actions sont priorisées selon leur niveau de criticité, leur impact sur la sécurité du SI, leur faisabilité et les ressources nécessaires à leur mise en œuvre.

La mise en œuvre s'appuie notamment sur le renforcement des contrôles d'accès, l'authentification multifacteur, la segmentation réseau, la protection des sauvegardes, la centralisation des journaux et la sensibilisation des utilisateurs.

Cette démarche permet d'assurer la cohérence entre les risques identifiés, les mesures de sécurité retenues et l'architecture cible.

7.3 Ressources nécessaires

La mise en œuvre du plan d'actions nécessite la mobilisation de ressources humaines, techniques et financières adaptées. Les ressources sont dimensionnées en fonction des actions prioritaires identifiées dans le plan d'actions de sécurité.

Type de ressource	**Ressources nécessaires**	**Rôle dans le projet**
Humaines	Direction générale	Validation des orientations, arbitrage et allocation des ressources
	DSI / Référent SSI	Pilotage de la mise en œuvre des mesures de sécurité
	Équipe informatique	Mise en œuvre technique et administration des solutions

Type de ressource	Ressources nécessaires	Rôle dans le projet
	DPO (à désigner)	Prise en compte des exigences relatives aux données personnelles
	Consultant cybersécurité	Accompagnement sur les mesures de sécurité et le SMSI
	Utilisateurs	Application des règles de sécurité et participation aux actions de sensibilisation
Techniques	Pare-feu UTM / segmentation VLAN	Contrôle des flux et cloisonnement du réseau
	MFA	Sécurisation des accès distants et privilégiés
	EDR	Renforcement de la protection des postes et serveurs
	SIEM	Centralisation et analyse des journaux de sécurité
	Solution de sauvegarde	Protection et restauration des données
	Solutions de chiffrement	Protection des données stockées
Financières	Budget du plan d'actions	Financement des mesures de sécurité prioritaires

Le budget prévisionnel du plan d'actions de sécurité s'élève à 195 000 € HT. Les dépenses seront engagées progressivement selon les priorités définies, les risques identifiés et les contraintes du projet. Le détail des coûts associés à chaque action est présenté dans le présent plan d'actions.

8. Planning et mise en œuvre du projet

8.1 Méthodologie de gestion du projet

La mise en œuvre du plan d'actions de sécurité repose sur une approche progressive et priorisée selon les risques identifiés.

Les actions sont organisées en fonction de leur niveau de priorité, de leur impact sur la sécurité du système d'information, de leur faisabilité technique et des ressources nécessaires à leur réalisation.

La démarche retenue s'articule autour des étapes suivantes :

1. **Priorisation des actions** à partir des risques identifiés et des objectifs de la PSSI ;
2. **Planification** des actions en tenant compte des dépendances techniques et organisationnelles ;
3. **Mise en œuvre** des mesures de sécurité par les équipes concernées ;
4. **Vérification** de la réalisation et de l'efficacité des mesures mises en place ;
5. **Suivi et amélioration continue** du dispositif à travers les indicateurs et les revues de sécurité.

Cette méthodologie permet de suivre l'avancement du plan d'actions, d'identifier les éventuels écarts et d'ajuster les priorités lorsque cela est nécessaire.

8.2 Planning de mise en œuvre

La mise en œuvre du plan d'actions est organisée progressivement selon l'ordre de priorité P1 – Critique, P2 – Haute et P3 – Moyenne. Les éventuelles dépendances techniques et organisationnelles sont prises en compte afin de garantir une mise en œuvre cohérente des mesures.

Phase	Actions principales	Priorité
Phase 1 – Sécurisation des accès	A1 – MFA ; A2 – Revue des habilitations ; A3 – Politique de mots de passe	P1 – Critique
Phase 2 – Protection des postes et détection	A6 – Déploiement d'un EDR	P1 – Critique
Phase 3 – Segmentation et isolation du réseau	A11 – Segmentation réseau et isolation des serveurs critiques	P1 – Critique
Phase 4 – Protection des données	A4 – BitLocker ; A5 – Sauvegardes chiffrées	P2 – Haute
Phase 5 – Supervision et détection	A7 – Centralisation des journaux / SIEM	P2 – Haute
Phase 6 – Facteur humain et prestataires	A8 – Sensibilisation ; A9 – Contrôle des accès prestataires	P2 – Haute

Phase	Actions principales	Priorité
Phase 7 – Maîtrise des changements	A10 – Gestion des changements	P3 – Moyenne

Le calendrier détaillé, les responsables, les échéances et l'état d'avancement de chaque action sont suivis dans les outils de pilotage du projet et dans le plan d'actions de sécurité présenté en **Annexe F**.

8.3 Suivi du projet et indicateurs

Le suivi du projet permet de mesurer l'avancement des actions de sécurité, de vérifier le respect des priorités et d'identifier les éventuels écarts. Un tableau de bord est utilisé pour assurer un suivi régulier de la mise en œuvre du plan d'actions.

Les principaux indicateurs retenus sont les suivants :

Indicateur	**Objectif**
Taux d'avancement des actions	Suivre le nombre d'actions réalisées par rapport au nombre total d'actions
Taux de réalisation des actions prioritaires	Vérifier que les actions les plus critiques sont traitées en priorité
Nombre d'actions en retard	Identifier les écarts par rapport au planning
Budget consommé	Comparer les dépenses engagées au budget prévisionnel
Taux de déploiement du MFA	Mesurer la couverture des comptes concernés
Taux de participation aux sensibilisations	Mesurer la participation des utilisateurs aux actions de sensibilisation
Nombre d'incidents de sécurité	Suivre l'évolution des événements de sécurité
Taux de conformité des habilitations	Vérifier la réalisation des revues périodiques des accès

Le tableau de bord est actualisé régulièrement par le DSI / Référent SSI et présenté lors des points de suivi du projet. Les résultats permettent d'identifier les écarts, de définir les actions correctives nécessaires et d'alimenter la démarche d'amélioration continue du SMSI.

Conclusion

Le présent Plan d'Actions de Sécurité traduit les orientations de la PSSI et les traitements issus de l'analyse des risques en mesures concrètes et priorisées.

Les actions retenues couvrent notamment le contrôle des accès, le chiffrement, la protection des postes et des données, la détection des incidents, la sensibilisation des collaborateurs, la maîtrise des accès prestataires ainsi que le renforcement de la segmentation et l'isolation des serveurs critiques.

Leur mise en œuvre progressive doit permettre à BioMarket de réduire les risques identifiés, de renforcer la résilience de son système d'information et d'améliorer son niveau de conformité aux exigences du SMSI, notamment dans le cadre de la préparation à la certification ISO/IEC 27001.

Le suivi des actions, des responsables, des échéances et des éventuels écarts sera assuré par la DSI dans le cadre du pilotage du SMSI. Le plan pourra être réévalué et mis à jour en fonction de l'évolution des risques, du système d'information et des priorités de BioMarket.